



Auditoría de Sistemas y Procedimientos de Control

Autor: Isaac Rodrigo Sanz Leyria

Asignatura: Administración de Sistemas

Universidad Tecnológica Nacional - Facultad Regional Mendoza



Ministerio de Educación
Universidad Tecnológica Nacional
Facultad Regional Mendoza

ÍNDICE

Consignas.....	3
1. Objetivo de control.....	4
7. Cláusula: Recursos humanos.....	4
7.2 Categoría: Durante el empleo.....	4
12. Cláusula: Seguridad en las operaciones.....	4
12.1 Categoría: Procedimientos y responsabilidades operativas.....	4
13. Cláusula: Gestión de la comunicación.....	4
13.2 Categoría: Transferencia de información.....	4
15. Cláusula: Relaciones con proveedores.....	5
15.1 Categoría: Seguridad de la información en las relaciones con el proveedor.....	5
2. Documentación.....	5
3. Procedimientos de control.....	7
4. Análisis a la organización.....	13
5. Observaciones y acciones correctivas.....	13



Ministerio de Educación
Universidad Tecnológica Nacional
Facultad Regional Mendoza

Consignas

Descripción:

En base a la información de la organización bajo estudio y los objetivos planteados en la presente guía, desarrolle los siguientes puntos asociados a la auditoría del SGSI en el caso bajo análisis:

1. Se deberán seleccionar 4 objetivos de control de diferentes cláusulas del programa de verificaciones “IT-6-2015-Revisión-Política-de-Seguridad-de-la-Información” a partir de la cláusula 6 (Organización) en adelante.
2. En base a los controles seleccionados, genere un listado de la Documentación para los Requerimientos Iniciales de la auditoría. Este debe identificar cada documento con el objetivo de control que se pretende verificar y el responsable de brindar ese documento actualizado.
3. Tomando como referencia el documento “Metodología de Trabajo de la Auditoría Informática”, desarrollar como mínimo 1 procedimiento de control sustantivo y 2 de cumplimiento para cada objetivo de control seleccionado, indicando el tipo.
4. Aplicar el programa de trabajo determinado en la organización bajo análisis, suponiendo un máximo del 50% en el nivel de cumplimiento. Indicar cumplimiento, riesgo y comentarios/referencias a papeles de trabajo.
5. Para cada uno de los incumplimientos identificados en el punto 4, generar las Observaciones adecuadas las cuales deben incluir: título, cuerpo, Fecha Obs., impacto y responsable de la observación.
6. Para cada una de las observaciones identificadas en el punto 5, generar las acciones correctivas adecuadas. Siempre que sea posible utilizar controles/salvaguardas del estándar CIS Controls, teniendo en cuenta el documento de correlación “CIS_Controls_v8_MAPPING_to_ISO.IEC_27001.2022”



1. Objetivo de control

La selección de los siguientes objetivos de control se fundamenta en el núcleo operativo de Loginter, una empresa dedicada a la logística integral que depende de manera crítica de la información, la tecnología y las relaciones con sus colaboradores y proveedores.

Dado el rol clave que cumple la información en los procesos de transporte, almacenamiento, seguimiento de pedidos y gestión de la cadena de suministro, la implementación de controles específicos de seguridad se vuelve esencial para garantizar la continuidad operativa, la confianza del cliente y el cumplimiento normativo.

Los controles seleccionados responden a las áreas más sensibles para la organización, incluyendo la gestión de recursos humanos, las operaciones diarias, la transferencia de información, y la relación con proveedores. Estos aspectos fueron priorizados por su impacto directo en la seguridad, eficiencia y trazabilidad de los procesos logísticos.

A continuación, se detallan las cláusulas, categorías y controles específicos tomados de la normativa ISO/IEC 27001 y la Disposición ONTI N.º 1/2015, adaptados al contexto de Loginter

7. Cláusula: Recursos humanos

7.2 Categoría: Durante el empleo

7.2.1 Control: Responsabilidad de la dirección

7.2.2 Control: Concientización, formación y capacitación en seguridad de la información

7.2.3 Control: Proceso disciplinario

12. Cláusula: Seguridad en las operaciones.

12.1 Categoría: Procedimientos y responsabilidades operativas

12.1.1 Control: Documentación de los procedimientos operativos

12.1.2 Control: Cambios en las operaciones

12.1.3 Control: Planificación de la capacidad

13. Cláusula: Gestión de la comunicación

13.2 Categoría: Transferencia de información

13.2.1 Control: Procedimientos y controles de intercambio de la información

13.2.2 Control: Acuerdos de Intercambio de Información



Ministerio de Educación
Universidad Tecnológica Nacional
Facultad Regional Mendoza

13.2.3 Control: Seguridad de la mensajería

13.2.4 Control: Acuerdos de confidencialidad

15. Cláusula: Relaciones con proveedores.

15.1 Categoría: Seguridad de la información en las relaciones con el proveedor

15.1.1 Control: Política de seguridad de la información para las relaciones con el proveedor

15.1.2 Control: Abordar la seguridad dentro de los acuerdos del proveedor

15.1.3 Control: Cadena de suministro de tecnologías de la información y comunicación

2. Documentación

Cláusula / Control	Documentación para los Requerimientos Iniciales de la auditoría	Responsable
7. Clausula: Recursos humanos		
7.2 Categoría: Durante el empleo		
7.2.1 - Responsabilidad de la dirección	- Contratos o actas de designación del personal directivo - Descripción de funciones del Director de Seguridad de la Información - Organigrama actualizado del área de IT	Gerente de RRHH / Gerente de IT
7.2.2 - Concientización, formación y capacitación	- Programa anual de capacitaciones en seguridad - Listado de asistentes a capacitaciones - Evaluaciones post capacitación - Políticas de concientización interna	Responsable de Seguridad de la Información / RRHH
7.2.3 - Proceso disciplinario	- Política disciplinaria de la empresa - Registros de incidentes tratados disciplinariamente - Actas o resoluciones internas por faltas a la seguridad	Gerente de RRHH
12. Cláusula: Seguridad en las operaciones.		
12.1 Categoría: Procedimientos y responsabilidades operativas		



12.1.1 - Documentación de los procedimientos operativos	● Procedimientos operativos documentados (ej.: para WMS, TMS, SICOP, etc.) ● Manuales técnicos y operativos ● Registro de revisiones y actualizaciones	Responsable de cada sistema (WMS: Supervisor de Almacén / TMS: Jefe de Transporte)
12.1.2 - Cambios en las operaciones	● Política de gestión de cambios ● Registros de solicitudes de cambio y autorizaciones ● Planes de prueba y aprobación antes del pasaje a producción	Jefe de Proyectos IT / Responsable de Seguridad Informática
12.1.3 - Planificación de la capacidad	● Informes de monitoreo de uso de recursos de IT (infraestructura, red) ● Proyecciones de demanda y planes de escalabilidad ● Reportes de Nagios / sistema de monitoreo	Líder de Infraestructura de IT
13. Cláusula: Gestión de la comunicación		
13.2 Categoría: Transferencia de información		
13.2.1 - Procedimientos de intercambio de información	● Políticas de intercambio de información (interno y externo) ● Instructivos de uso seguro de canales como email, APIs y FTP ● Reportes de incidentes por canales inseguros	Responsable de Seguridad de la Información
13.2.2 - Acuerdos de intercambio de información	● Contratos con terceros que involucren datos sensibles ● Acuerdos de nivel de servicio (SLAs) ● Cláusulas de privacidad y seguridad	Gerente Legal / Responsable de Compras y Proveedores
13.2.3 - Seguridad de la mensajería	● Configuración de herramientas de correo corporativo ● Políticas de cifrado, autenticación y antiphishing ● Logs de filtrado de spam / alertas	Responsable de Seguridad Informática
13.2.4 - Acuerdos de confidencialidad	● NDA firmados con empleados y proveedores ● Cláusulas de confidencialidad en contratos laborales y comerciales	Gerente de RRHH / Gerente de Legales
15. Cláusula: Relaciones con proveedores.		
15.1 Categoría: Seguridad de la información en las relaciones con el proveedor		



15.1.1 - Política de seguridad en relaciones con proveedores	• Política formal sobre seguridad en proveedores • Procedimiento de evaluación de seguridad de terceros	Responsable de Seguridad de la Información
15.1.2 - Seguridad en acuerdos con proveedores	• Contratos con cláusulas de seguridad • Requisitos técnicos de seguridad exigidos (p. ej.: cifrado, backups, etc.)	Gerente de Compras / Jefe de Seguridad Informática
15.1.3 - Cadena de suministro TIC	• Inventario de proveedores TIC y subcontratistas • Evaluaciones de riesgos en la cadena de suministro • Planes de continuidad en caso de interrupción	Gerente de IT / Responsable de Proyectos

3. Procedimientos de control

A partir de lo realizado en las consignas anteriores, se realizó para cada control, los procedimientos con su respectivo tipo, descripción y objetivo. Se tuvo en cuenta lo siguiente:

- **Procedimientos de cumplimiento:** Son procedimientos que proporcionan evidencia de que los controles claves existen y son aplicados en forma efectiva.
- **Procedimientos sustantivos:** Son procedimientos que proporcionan evidencia directa sobre la validez de las transacciones y los datos que proporciona el sistema de información.

Además para clasificarlos se tuvo en cuenta los procedimientos y técnicas que pueden utilizarse durante la ejecución de una auditoría, como por ejemplo:

- **Revisión:** Consiste en el análisis de las características que debe cumplir una actividad, informe, documento, etc. Sirve para seleccionar operaciones que serán verificadas en el curso de la auditoría.
- **Confrontación:** Consiste en el cotejo de información contenida en registros contra el soporte documental de las transacciones registradas.
- **Comparación:** Consiste en establecer las diferencias entre las operaciones realizadas y los criterios, normas, procedimientos y prácticas que se utilizan habitualmente.
- **Indagación:** Consiste en la obtención de manifestaciones mediante entrevistas a funcionarios y empleados o personas relacionadas con las operaciones.
- **Inspección:** Es el examen físico y ocular de ciertos activos tangibles como ser bienes de consumo o de uso, insumos, obras, valores, etc., para comprobar su real existencia y autenticidad.
- **Análisis:** Es la separación de una operación, procedimiento o actividad en sus elementos componentes, para establecer su conformidad con criterios de orden normativo y técnico.



7.2.1 – Responsabilidad de la dirección			
Procedimiento	Tipo	Descripción	Objetivo
Sustantivo	Revisión documental	Revisar contratos o actas de designación del personal directivo y el organigrama vigente del área de IT.	Verificar que las funciones críticas estén correctamente asignadas y respaldadas formalmente.
Cumplimiento	Indagación	Entrevistar al Responsable de Seguridad de la Información sobre sus funciones y responsabilidades.	Validar que conozca sus responsabilidades y que las esté cumpliendo según lo declarado.
Cumplimiento	Comparación	Comparar funciones del RSI según documentación con actividades reales (sistemas, políticas, reportes).	Detectar desvíos entre lo declarado y lo operativo.
7.2.2 – Concientización, formación y capacitación			
Sustantivo	Inspección documental	Revisar el programa anual de capacitaciones y el listado de asistentes.	Verificar que se brinden capacitaciones planificadas y registradas.
Cumplimiento	Revisión documental	Analizar políticas de concientización y registros de evaluación post capacitación.	Evaluar si las capacitaciones tienen impacto en el personal.



Cumplimiento	Indagación	Entrevistar empleados al azar para confirmar su participación en capacitaciones.	Comprobar la efectividad de las acciones de concientización.
7.2.3 – Proceso disciplinario			
Sustantivo	Revisión documental	Analizar políticas disciplinarias y registros de incidentes con sanciones aplicadas.	Corroborar la existencia y aplicación del régimen disciplinario.
Cumplimiento	Inspección	Solicitar evidencia de aplicación real del proceso disciplinario ante faltas a la seguridad.	Confirmar la ejecución práctica de la política.
Cumplimiento	Comparación	Comparar las sanciones aplicadas con lo establecido en la política.	Confirmar que el procedimiento disciplinario fue aplicado como lo establecido en la política.
12.1.1 – Documentación de procedimientos operativos			
Sustantivo	Revisión documental	Evaluar los manuales técnicos y operativos de los sistemas WMS, TMS, etc.	Comprobar que los procesos están formalmente documentados.
Cumplimiento	Inspección	Verificar la existencia de revisiones o actualizaciones recientes.	Validar la vigencia y uso de los procedimientos.
Cumplimiento	Comparación	Comparar la documentación con las tareas realmente realizadas.	Detectar diferencias entre lo documentado y lo ejecutado.
12.1.2 – Cambios en las operaciones			



Sustantivo	Revisión documental	Evaluar la política de gestión de cambios y los registros de cambios aprobados.	Verificar que los cambios estén planificados y autorizados.
Cumplimiento	Observación	Presenciar un cambio programado para ver si se siguen los pasos definidos.	Corroborar la aplicación del procedimiento formal.
Cumplimiento	Comparación	Comparar cambios implementados con los planes de prueba previos.	Asegurar que se realizó la validación antes de aplicar el cambio.
12.1.3 – Planificación de la capacidad			
Sustantivo	Revisión técnica	Analizar reportes de uso de recursos de IT.	Evaluar si se realiza monitoreo preventivo.
Cumplimiento	Revisión documental	Consultar planes de escalabilidad ante picos de demanda.	Corroborar que se planifique la infraestructura.
Cumplimiento	Indagación	Entrevistar al Responsable de Infraestructura sobre acciones ante sobrecarga.	Confirmar que exista un enfoque anticipado.
13.2.1 – Procedimientos y controles de intercambio de información			
Sustantivo	Revisión documental	Verificar la existencia de instructivos para el uso seguro de email, FTP, APIs.	Comprobar que existan controles formales sobre el intercambio de información.
Cumplimiento	Observación	Verificar que los usuarios sigan el instructivo en sus prácticas.	Evaluar el cumplimiento operativo de las normas.



Ministerio de Educación
Universidad Tecnológica Nacional
Facultad Regional Mendoza

Cumplimiento	Indagación	Consultar a usuarios y responsables si conocen los procedimientos.	Determinar nivel de concientización.
13.2.2 – Acuerdos de intercambio de información			
Sustantivo	Revisión contractual	Analizar contratos con terceros que involucren intercambio de datos.	Verificar existencia de cláusulas de seguridad y privacidad.
Cumplimiento	Inspección	Pedir evidencia de acuerdos firmados y activos.	Confirmar vigencia y cumplimiento documental.
Cumplimiento	Comparación	Comparar cláusulas con los requerimientos internos de seguridad.	Ver si se están exigiendo las medidas adecuadas.
13.2.3 – Seguridad de la mensajería			
Sustantivo	Inspección técnica	Evaluar configuración de correo (cifrado, filtros de spam, autenticación).	Verificar si los canales de mensajería son seguros.
Cumplimiento	Revisión documental	Consultar políticas de uso de correo y alertas de seguridad.	Confirmar la existencia de lineamientos internos.
Cumplimiento	Indagación	Preguntar a los empleados si conocen y respetan las normas de uso del correo.	Determinar concientización sobre el uso de mensajería segura.
13.2.4 - Acuerdos de confidencialidad			



Sustantivo	Revisión documental	Verificar la existencia de NDAs firmados y cláusulas contractuales.	Confirmar la protección legal de la información.
Cumplimiento	Inspección	Evaluar contratos laborales y acuerdos con proveedores activos.	Ver si todos los actores están cubiertos por acuerdos.
Cumplimiento	Comparación	Comparar cláusulas firmadas con las políticas internas.	Detectar si falta algún compromiso formal requerido.
15.1.1 – Política de seguridad en relaciones con proveedores			
Sustantivo	Revisión documental	Evaluar la política formal de seguridad para relaciones con proveedores.	Comprobar que la organización tenga criterios definidos.
Cumplimiento	Inspección	Verificar procedimientos de evaluación de seguridad de proveedores.	Confirmar su aplicación práctica.
Cumplimiento	Indagación	Consultar al Responsable de Seguridad sobre cómo se aplican los controles.	Verificar consistencia entre política y práctica.
15.1.2 – Seguridad dentro de los acuerdos del proveedor			
Sustantivo	Revisión contractual	Evaluar contratos con proveedores con cláusulas de cifrado, backups, etc.	Verificar que se formalicen los requisitos de seguridad.
Cumplimiento	Inspección	Consultar si los proveedores cumplen con las condiciones acordadas.	Evaluar grado de cumplimiento externo.



Ministerio de Educación
Universidad Tecnológica Nacional
Facultad Regional Mendoza

Cumplimiento	Comparación	Comparar lo acordado contractualmente con lo que realmente se aplica.	Detectar brechas en la ejecución.
15.1.3 – Cadena de suministro TIC			
Sustantivo	Revisión documental	Analizar inventario de proveedores TIC y reportes de evaluación de riesgos.	Comprobar que se analice la seguridad en toda la cadena de suministro.
Cumplimiento	Revisión documental	Evaluar si existen planes de continuidad documentados ante interrupciones.	Verificar medidas ante fallas de terceros.
Cumplimiento	Indagación	Entrevistar al gerente de IT o proyectos sobre planes de contingencia en proveedores TIC.	Confirmar que se tomen medidas proactivas.

4. Análisis a la organización

La consigna fue realizada en el excel con el nombre:

Grupo5_Loginter-IT-N-6-2015-GNyPE-Revision-Politica-de-Seguridad-de-la-Infomacion

5. Observaciones y acciones correctivas

Las consignas 5 y 6 fueron realizadas en el excel con el nombre:

Grupo5_Loginter_Observaciones y acciones correctivas